

CYROPAY LTD

Third-Party Vendor Risk Assessment Report

Document Classification: Internal
Document ID: VRA-RPT-001
Version: 1.0
Document Owner: Chief Information Security Officer (CISO)
Effective Date: May 2026
Review Date: May 2027
Status: Approved

Executive Summary

CyroPay Ltd commissioned a formal Third-Party Vendor Risk Assessment (VRA) of its three critical suppliers in May 2026: Amazon Web Services (AWS), Stripe, and Salesforce. The assessment was conducted by the GRC team in accordance with CyroPay's Third-Party Security Policy (POL-008), aligned to ISO/IEC 27001:2022 Annex A controls and the Digital Operational Resilience Act (DORA) ICT third-party risk requirements under Articles 5, 9, 11, 17, 19, 28, and 30.

Each vendor was assessed against a 25-question risk questionnaire across 10 security domains. Responses were scored (0–2 per question; maximum 50) and supplemented by review of publicly available assurance documentation including ISO 27001 certificates, SOC 2 Type II reports, and PCI DSS attestations.

Vendor	Score /50	Score %	Risk Rating	Gaps	DORA Alignment
Amazon Web Services	47/50	94.0%	Low	3	Broadly compliant
Stripe	45/50	90.0%	Low	5	Broadly compliant
Salesforce	36/50	72.0%	Medium	13	Partial — tenant actions required

All three vendors achieved scores above 70%, placing them within the Low to Medium risk categories. The most significant risk exposure identified across the assessment relates not to vendor platform deficiencies but to CyroPay's own governance of its vendor relationships — specifically, the absence of contractual notification clauses, formal access reviews within vendor platforms, and documented exit plans.

1. Scope and Methodology

1.1 Assessment Scope

This assessment covers the three vendors identified as critical suppliers under CyroPay's ISMS scope statement and Third-Party Security Policy:

- Amazon Web Services (AWS) — primary cloud infrastructure provider (IaaS/PaaS)
- Stripe — PCI DSS-compliant payment processor under hosted payment page implementation
- Salesforce — CRM platform holding merchant and partner relationship data

1.2 Methodology

The assessment was conducted using the following approach:

- Completion of the CyroPay Vendor Risk Questionnaire (VRA-Q001) covering 25 questions across 10 security domains.
 - Review of vendor-published assurance documentation: ISO 27001 certificates, SOC 2 Type II reports, PCI DSS Attestations of Compliance (AoC), and security white papers.
 - Review of contractual terms and service agreements for each vendor.
 - Scoring against a 0–2 scale per question (0=No/Not Met; 1=Partial; 2=Yes/Fully Met); maximum score 50.
 - Risk rating based on score percentage: Low ≥85%; Medium 70–84%; High 50–69%; Critical <50%.
 - ISO/IEC 27001:2022 Annex A and DORA regulatory alignment review.
-

2. Regulatory Alignment

2.1 ISO/IEC 27001:2022

The assessment questionnaire maps directly to the following ISO/IEC 27001:2022 Annex A control domains:

Control Domain	Annex A Controls	Assessment Questions
Information Security Governance	A.5.1, A.5.2	Q01–Q03
Access Control	A.5.17, A.5.18, A.8.2	Q04–Q06
Data Protection	A.8.24, A.5.12, A.8.10	Q07–Q09
Vulnerability Management	A.8.8, A.8.29, A.8.25	Q10–Q12
Incident Response	A.5.24, A.5.26, A.5.27	Q13–Q15
Business Continuity	A.5.29, A.5.30, A.8.14	Q16–Q18
Supply Chain	A.5.21, A.5.22	Q19–Q20
Audit & Compliance	A.5.35, A.5.36	Q21–Q23
Physical Security	A.7.1	Q24
Exit & Data Return	A.5.11	Q25

2.2 DORA Alignment

The assessment addresses CyroPay's obligations under the Digital Operational Resilience Act (DORA) Regulation (EU) 2022/2554, applicable to CyroPay as a regulated payment institution. Key DORA requirements addressed include:

DORA Article	Requirement	Assessment Coverage
Art. 5	ICT risk management framework	Q01–Q03 (Governance)
Art. 9	ICT security controls	Q04–Q12 (Access, Data, Vuln)
Art. 11	ICT Business Continuity	Q16–Q18 (BCP/DRP)
Art. 17	ICT-related incident	Q13–Q15 (IR)

	management	
Art. 19	Major ICT incident notification	Q14 (24hr notification)
Art. 28	Third-party risk management	Q19–Q20, Q25 (Supply chain, exit)
Art. 30	Contractual provisions with ICT third parties	Q21–Q22 (Audit rights)

3. Vendor Findings

3.1 Amazon Web Services

Score: 47/50 (94.0%) — Risk Rating: Low

AWS demonstrates an industry-leading security posture underpinned by an extensive portfolio of third-party certifications. The AWS Shared Responsibility Model clearly delineates platform-level controls (AWS's responsibility) from tenant-level controls (CyroPay's responsibility). AWS scored the highest of the three vendors assessed.

The primary gaps identified relate to the structural limitations of hyperscale cloud procurement — audit rights are restricted to CyroPay's own account perimeter, and incident notification timelines are governed by AWS's Health Dashboard rather than direct contractual SLAs meeting CyroPay's 24-hour requirement. CyroPay should address these through contractual amendment or AWS Enterprise Support engagement.

Action 1: Negotiate contractual 24-hour security incident notification SLA or subscribe to AWS Health API for automated alerting.

Action 2: Establish a quarterly process to review AWS sub-processor list changes.

Action 3: Obtain and review AWS SOC 2 Type II report annually via AWS Artifact.

3.2 Stripe

Score: 45/50 (90.0%) — Risk Rating: Low

Stripe's security controls are among the most rigorous in the payments sector. As a PCI DSS Level 1 Service Provider operating a hosted payment page implementation, Stripe's environment processes cardholder data entirely within its own PCI-compliant

boundary. CyroPay retains only tokenised references, materially limiting its exposure to payment card data risk.

Gaps identified relate primarily to transparency of internal controls (PAM practices, post-incident reporting) and sub-processor governance. These are common limitations of SaaS vendors and are partially mitigated by Stripe's SOC 2 Type II report and PCI DSS AoC.

Action 1: Request Stripe's SOC 2 Type II report under NDA and review annually.

Action 2: Negotiate contractual 24-hour incident notification for events affecting CyroPay transaction data.

Action 3: Establish a quarterly process to review Stripe's sub-processor and data sub-processor list.

Action 4: Request evidence of PAM controls via Stripe's security questionnaire response.

3.3 Salesforce

Score: 36/50 (72.0%) — Risk Rating: Medium

Salesforce presents a Medium risk profile. The Salesforce platform itself maintains strong security controls evidenced by ISO 27001, SOC 2, ISO 27017, and ISO 27018 certifications. However, the assessment identified that a substantial proportion of the gaps relate to CyroPay's own governance of its Salesforce tenant rather than platform-level deficiencies.

Specifically, CyroPay has not implemented formal access reviews for Salesforce users, has not configured data classification and retention rules within the platform, and has not developed a Salesforce exit plan. Given that Salesforce holds Confidential merchant and partner data, these tenant-side gaps represent a material risk requiring prompt remediation.

Action 1 (URGENT): Implement quarterly Salesforce user access reviews covering all active accounts and permission sets.

Action 2: Configure Salesforce data classification fields and apply handling rules consistent with POL-006.

Action 3: Define and implement data retention and deletion rules within Salesforce aligned to CyroPay's retention policy.

Action 4: Develop a documented Salesforce exit plan including data export procedures and deletion confirmation.

Action 5: Negotiate 24-hour incident notification clause and sub-processor change notification provisions.

Action 6: Obtain Salesforce SOC 2 Type II report and review annually.

Action 7: Establish quarterly Salesforce security configuration review.

4. Risk Register — Vendor Risks

The following vendor-specific risks have been identified and should be added to CyroPay's Risk Register:

Risk ID	Vendor	Risk Description	Rating	Treatment	Owner	Target
VR-001	All vendors	Insufficient contractual notification SLAs — vendors do not guarantee 24-hour security incident notification	High	Mitigate — renegotiate contracts	CISO	Aug 2026
VR-002	Salesforce	CyroPay Salesforce tenant lacks formal access reviews, data classification config, and exit plan	High	Mitigate — internal remediation programme	IT Manager	Jul 2026
VR-003	All vendors	Sub-processor change notification not proactively provided — fourth-party risk unmonitored	Medium	Mitigate — establish monitoring process	CISO	Aug 2026
VR-004	AWS / Stripe	Customer audit rights	Medium	Accept with compensating	CISO	Ongoing

		restricted — reliance on third-party assurance reports only		controls — annual SOC 2 review		
VR-005	Salesforce	No documented exit plan for Salesforce — data recovery and deletion not assured	Medium	Mitigate — develop exit plan	IT Manager	Sep 2026

5. Conclusions and Recommendations

Overall, CyroPay's three critical vendors demonstrate sound security postures supported by recognised third-party certifications. None of the vendors assessed presents an unacceptable inherent risk to CyroPay's operations. However, the assessment identified a consistent pattern of governance gaps that CyroPay must address:

5.1 Contractual Enhancements (All Vendors — Priority 1)

Negotiate 24-hour security incident notification clauses into all three vendor agreements.

Ensure all contracts include explicit audit rights provisions (or reference to SOC 2/ISO 27001 as compensating assurance).

Include data return and deletion obligations upon contract termination in all agreements.

Include sub-processor change notification requirements in all vendor contracts.

5.2 CyroPay Tenant Governance (Salesforce — Priority 1)

Implement quarterly Salesforce user access reviews immediately.

Configure data classification and retention rules within Salesforce by July 2026.

Develop Salesforce exit plan by September 2026.

5.3 Ongoing Assurance Programme (All Vendors — Priority 2)

Establish an annual vendor review cycle: obtain and review SOC 2 Type II reports for all three vendors.

Implement a quarterly sub-processor monitoring process for all three vendors.

Schedule formal annual vendor risk re-assessments using VRA-Q001.

Register VRA findings and remediation actions in the CyroPay Risk Register.

6. Document Control

Version	Date	Author	Changes
1.0	May 2026	CyroPay GRC Team	Initial version